Stoquify ordered remediation and delivery roadmap

Prepared 2026-09-05. This is a work package, not release authorization. Estimates assume one engineer and access to the named reviewers.

The provisional delivery target remains **QUALIFIED_FOR_CONTROLLED_PHASE_2B_PILOT** from the August 28 plan. No later accepted replacement was established. A controlled pilot and production release remain separate milestones. The current audit can support continued local engineering; it cannot authorize activation.

Order	Package	Outcome	Dependencies	Acceptance
1	P01 Dependency reproducibility/security	One tested dependency graph with patched framework and spreadsheet parser	Isolated install/build environment	Verified patched versions, reviewed lockfile diff, frozen install, auth/image/import/build smoke
1	P02 Private media and durable storage configuration	Tenant photos have one enforceable delivery boundary	Private store and retention choice	Legacy/new/API/optimizer access-denial matrix, persistence and migration reconciliation
1	P03 API delegation inventory	Six currently unclassified endpoints have explicit verified guard mappings	Existing service/route tests	Unknown routes still fail; removing a delegated guard fails; no false broad auth-prefix exemption
2	P04 Runtime operations	Logs arrive safely; resource limits and worker cancellation are measurable	Operator, trusted ingress and test transports	Synthetic log/alert/recovery proof, two-worker limit and timeout tests
2	P05 Financial correctness/concurrency	Historical COGS is stable; concurrent reversals are deterministic	Finance semantics, isolated PostgreSQL	Ledger tie-out and real transaction concurrency/failure proof
2	P07 Native approval register	Authentic human decisions produce usable references	P02 private evidence storage; real establishment authority	Establishment and decision negative tests; issued references verified by consumers
3	P06 X1 evidence refresh	Current authenticated EN/FR evidence and approved budget result	Stable candidate, real approvals, approved fixture identity	42 cases plus aggregation, source/fixture/build binding and separate performance assessment
4	P08 Candidate release assurance	Candidate-specific build, migration, statutory, operations and ownership evidence	P01–P07 as applicable to approved scope	Existing B01–B10 and Gate 017 criteria satisfied
5	Controlled Phase 2B	Explicit bounded activation and monitored pilot	Gate 017 and B11	Pilot scope, rollback, support and exit proof
6	Phase 3 production	Evidence-bound production decision	Successful pilot and B12	Existing 34-check decision and actual authority

The same numbering is used in findings.json. P07 can be developed before X1 approval exists. Its setup draft does not require an earlier register ID. Activation requires a real establishment act and verification, which prevents a circular approval prerequisite.

P01: reconcile the installation before release (1–2 days plus import compatibility work)

Affected files: package.json, package-lock.json, pnpm-lock.yaml, .github/workflows/ci.yml, spreadsheet-import consumers and focused tests. CI currently runs npm ci; local node_modules was installed from a different graph. Do not replace the live shared node_modules during concurrent work.

Create a temporary isolated install from the current package files, with lifecycle scripts inspected/disabled initially. Upgrade Next.js to the vendor-patched 15.5 maintenance line (the verified August release is 15.5.24); use its compatible lint package. For xlsx, verify the official patched distribution and integrity or prepare a parser replacement. Compare the resulting lock graph and choose one authoritative package manager; until that decision is encoded, both supported installation paths must resolve the intended security versions. Do not hand-edit transitive integrity hashes.

Retain the previous package files as rollback evidence, but do not deploy a known affected version as an unqualified security rollback. Validate a frozen install, build, HTTPS authentication, optimized images, CSV/XLSX imports and the application's actual operating-system deployment. This audit did not install or claim these updates.

P02: private media and configuration (3–5 days)

Affected files: actions/storage/photo-upload-actions.ts, actions/storage/storage-config-actions.ts, app/api/uploads/[...path]/route.ts, EnhancedImageUploadButton and every inventory/image consumer discovered through imports, storage types, schema/migration and edge/static configuration.

Use private object storage, or a configurable private directory outside public for local development. Serve through a server-owned organization/asset lookup with permission checks. Keep opaque stable references in records. Use authenticated browser image delivery; an image optimizer that cannot forward user credentials must not become an alternate public path. The upload form, list cells, thumbnails and deletion flow must all accept the new representation. Validate actual image bytes and bound dimensions and size.

Introduce durable organization storage configuration with explicit defaults and version checks. Before migrating, inventory only metadata of existing assets and references, copy to private storage, verify hashes/counts, reconcile URLs and test authorized display. Deny the legacy public path and purge caches at cutover. Keep recovery copies private. Do not delete originals until migration verification and recovery conditions are met. A proxy/CDN serving the old folder must also be reconfigured.

Acceptance includes anonymous and foreign-tenant requests to the original URL, new URL and optimizer URL, revoked-session reads, owner reads, replacement/deletion, restart-persistent settings and interrupted migration recovery. The API cache correction already implemented is only one part of this package.

P03: explicit API guard delegation (1–2 days)

Current required mappings:

- Customer statement GET and actions POST → services/accounting/customer-statement-access.service.ts: signed token, live registry, snapshot hash, expiry/revocation and action scope.
- Supplier envelope GET and proposal POST → services/purchase-order/supplier-po-acknowledgement.service.ts: signed envelope, live token, snapshot integrity and proposal-only external mutation.
- Internal abandoned-run reconciler → agent-reconciler-auth.service.ts and agent-reconciler-invocation.service.ts: configured secret, scheduler envelope, freshness and replay/lease control.

- Referral GET → services/referrals: intentional bounded public redirect and attribution, rather than organization-session authorization.

Extend scripts/api-route-guard-inventory.js with exact endpoint-to-service contracts and evidence dependencies. Do not broadly exempt entire directories. Add negative tests that remove or invalidate the delegated gate, expiry and organization binding. Keep unclassified routes blocked. Static token searches remain screening; the route/service tests provide behavioral evidence. The six endpoints are not presumed unprotected merely because this inventory lacks their mapping.

P04: log transport and bounded operations (2–4 days)

Affected files: lib/logger.ts, startup instrumentation, existing canonical redaction, middleware.ts, agent execution adapters and runner/lease persistence.

Initialize a structured server sink through approved startup configuration. Reuse redaction and correlation contracts; do not dump raw request contexts or driver exceptions to console. Define retention, access and alert recipients. Verify delivery with a harmless synthetic event and deliberate transport outage. Database audit records retain their own transactional requirements.

Agree the ingress header contract, bounded fallback and shared rate-limit store. Test two replicas and expired-key cleanup. Pass cancellation/deadlines to agent adapters; retain a lease/version fence against late completion. Promise.race alone cannot stop ongoing work. Extend CSP with nonces/hashes in a measured browser rollout; do not simply remove unsafe-inline and break the application.

P05: stable finance facts and concurrency (3–5 days)

Affected files: services/analytics/financial-analytics.service.ts, its service-owned input/source adapters and tests; services/accounting/posting.service.ts and PostgreSQL fixtures.

Historical COGS should follow posted inventory valuation/ledger recognition, including partial deliveries and returns. Confirm recognition-date and currency semantics with the finance owner. Where provenance is missing, expose an unavailable/reconciliation-required state. Do not backfill historical cost from the current item price or rewrite posted journals. Compare old/new read models on known fixtures and preserve an explicit version.

For reversal numbering, first reproduce two concurrent transactions on separate journals. The existing unique constraint is a useful safeguard. Choose a tenant/date sequence or retryable counter after observing the failure, retaining idempotency and atomic close invalidation. Test lost races, duplicate requests and rollback with actual PostgreSQL, not only mocked update counts.

P06: fresh X1 capture (1–2 days after inputs)

The current preflight requires product budget approval, evidence authorization, a valid run ID and approved browser storage state. The run ID is generated by engineering; it is not a user-provided approval ID. Authenticated test state comes from signing in as the approved external-accountant fixture user and must remain private.

Use the existing version-2 measurement helper. Capture cold and warm runs separately after the development build settles. Record exact source digest, build identifier, fixture revision, role, dates/filters and authorization revision. Confirm loading, failed/denied, valid empty, filtered no-results, table rows and summary layouts explicitly. Collect all 42 route/locale/viewport cases plus aggregation, then assess each actual approved budget. List-only success is not capture evidence. Route-matrix completeness alone is not budget compliance.

P07: native approval register (four staged implementation slices)

The September 3 blueprint and operating guide are the starting design. This audit has not implemented the register.

1. Add the proposed register/policy, authority appointment, request revision, artifact, decision, verification and event models using non-destructive migrations and tenant-scoped references. Create a setup draft without an earlier approval ID. Verify the real owner's authority and the setup verifier's evidence before activation.
2. Build private artifact storage and immutable revisions. Compute hashes from stored bytes. Keep establishment and each decision as append-only history; supersession/revocation changes eligibility, not the historical signed record.
3. Add role-aware EN/FR pages for My approvals, Decision, Record and Authorities. Bind fresh authentication to the exact revision and payload, enforce role conflicts and scoped appointments, issue server IDs/timestamps and retain atomic audit events.
4. Add a typed validity resolver used by X1. A valid same-scope decision supplies approval reference, verified time, signature/verification reference and permanent reviewer-accessible URI. Reject missing, expired, revoked, superseded and inaccessible evidence.

Affected areas: prisma schema/migrations; new services/governance register ownership; protected actions/governance; dashboard governance pages; private artifact adapter; permissions/navigation/messages; X1 binding and verification consumers. Reuse existing fresh-auth and tenant primitives, not the provider simulator.

Compatibility: keep the provider adapter contract intact. POL-004 is a separate optional standing automation-delegation path; human-native decisions should not require machine delegation. Migration rollback disables new writes and retains issued records. Test simultaneous decisions, stale revisions, duplicate submissions, foreign-tenant links, self-approval, owner departure, failed artifact storage, revocation and interrupted audit writes before pilot enablement.

P08: consolidate evidence and freeze (after material fixes)

Use one source-bound evidence bundle indexed by candidate digest, environment, fixture, policy and command version. Historical August results can supply context, not silently certify September changes. Build and runtime evidence require a fresh candidate.

The existing historical dependency graph makes production-target proof an ancestor of the Phase 2B freeze. The release authority should resolve whether Phase 2B requires production-target proof or an isolated pilot/rehearsal target. Prepare separate development, test, pilot and production views while preserving target-specific release enforcement. Do not change that policy merely to obtain a green result.

Consolidate duplicate metadata collection across B04/B07/B08 and B09/B10: one credential reference can support distinct strength, rotation and operating checks; one immutable candidate can support several decisions. These checks serve different risks and should remain independently evaluated. No gate retirement has been authorized or implemented in this run.

Preserve the gate suite until equivalent coverage and affected consumers are verified. For the next milestone, entry requires the approved narrow scope, patched reproducible candidate, closed high-risk applicable findings, trustworthy technical evidence, real ownership and scoped activation authority. Exit requires observed pilot behavior, rollback/recovery proof, reconciled business data and accepted exit decisions.